



Penetration test report.

Cyberlou Corporation
470 Final SP26 CTF Assessment

Prepared by HackForce One

Engagement window · April 12 – April 16, 2026
Report date · April 30, 2026

N E T W O R K M A P

Network topology.

Cyberlou Corporation engagement scope and post-engagement state across both subnets.



C O N T E N T S

What’s inside.

- 1. Executive summary 4
- 2. Scope of assessment 6

3. Methodology8

4. Severity matrix9

5. Findings10

F-01 Sensitive path disclosure via robots.txt10

F-02 Weak SSH password policy on HRIS server12

F-03 Plaintext user inventory in open directory14

F-04 Weak Webmin administrator password15

F-05 SMB signing not required on Windows endpoint16

F-06 NTLMv2 hash capture and offline crack17

F-07 Plaintext credentials in Operations SMB share19

F-08 Database admin credentials in SMB share21

F-09 Persistent backdoor on Windows endpoint22

F-10 Finance server compromise via Webmin backdoor24

F-11 Persistence account on Finance server26

F-12 Customer credit card data exfiltration28

F-13 Default credentials and cached data on printer29

F-14 Unauthorized access to internal database server30

6. Vulnerability summary32

7. Recommendations34

8. Conclusion36

Appendix A Screenshot capture index37

Executive summary.

A four-day engagement against the Cyberlou Corporation environment that produced fourteen findings and a complete chain from public-facing port scan to root on the Finance server.

HackForce One conducted a black-box penetration test of Cyberlou Corporation’s internal network across two subnets covering five production systems: an HRIS server, a Finance server, a Windows endpoint, a network printer, and an internal database server. The engagement ran in April 2026 against a fully scoped lab environment and produced fourteen findings, of which eight are rated Critical and four High.

The most consequential observation is that the entire compromise chain pivoted off a single weak control: a four-digit numeric SSH password policy on the HRIS server, which fell to an offline brute force inside two hours. From that foothold the team enumerated the second subnet, captured an NTLMv2 challenge-response from a Windows endpoint with SMB signing disabled, harvested plaintext credentials from a publicly readable SMB share, and chained those into administrative access on the Finance server, the internal database server, and a backdoor on the Windows endpoint. Every credential reused across the environment shortened the chain by one step.

Key findings

- Critical: A four-digit numeric SSH password policy on the HRIS server was brute-forceable inside two hours and gave the team the initial foothold for every subsequent finding.
- Critical: The HRIS web portal disclosed sensitive paths via robots.txt and exposed a directory listing containing a document that named all valid users and the password policy itself.
- Critical: The Windows endpoint (DESKTOP-V4C365B) had SMB signing disabled. An NTLMv2 challenge-response was captured via Responder and cracked offline.
- Critical: An SMB share named Operations contained a plaintext credentials file and a database administration training document. Both held credentials that authenticated to other systems.
- Critical: The Finance server was fully compromised. Root access was obtained, a persistence account was created, the Webmin administrative password was recovered, and a single customer credit card record was retrieved as proof of database access.
- High: A persistent administrative backdoor was created on the Windows endpoint as part of the engagement and must be removed.
- High: The Konica printer accepted a default-style administrative password and exposed cached print jobs, including a customer invoice, on an unauthenticated /cache endpoint.

Attack chain at a glance



Scope of assessment.

What was authorized, when the team was active, and which systems sat inside the rules of engagement.

The engagement covered the systems listed below. All testing was authorized in writing as part of the 470 Final SP26 CTF Assessment.

Engagement timing

Engagement window	April 12, 2026 – April 16, 2026
Active testing hours	Approximately 38 hours across the four-day window
Testing position	Internal network, simulated insider with attacker workstation on 192.168.1.0/24
Authorization	Written authorization granted by the course instructor as part of the 470 Final SP26 CTF Assessment
Out of scope	Denial of service, social engineering of staff, physical security, third-party SaaS providers

Target systems

S Y S T E M	A D D R E S S	S E R V I C E S	S T A T U S
HRIS Server	hris.cyberlou.xyz / 192.168.0.172	SSH 22, HTTPS 443, MySQL 3306, Webmin 8200	Compromised
Finance Server	finance.cyberlou.xyz / 192.168.3.8	SSH 22, HTTP 80, Webmin 28840	Compromised
Windows Endpoint	DESKTOP-V4C365B / 192.168.3.120	SMB 445, RDP 3389, MSRPC 135	Compromised
Konica Printer	192.168.3.116	HTTP 8200, MySQL 3306	Compromised
Database Server	192.168.3.228	MySQL 3306	Accessed

Methodology.

The phased approach the team followed and the tools that produced each piece of evidence in this report.

The engagement followed a four-phase methodology aligned with the Penetration Testing Execution Standard. Each phase fed evidence into the next, and every credential, hash, and document recovered during the engagement is held in the team’s secured engagement notes rather than reproduced in this deliverable.

3.1 Phase summary

- Reconnaissance and scanning. Subdomain enumeration, robots.txt analysis, Nmap port and service discovery across both /24 subnets, and SMB security mode enumeration.
- Credential acquisition. Online brute force of an SSH service with a constrained wordlist, NTLMv2 capture via Responder, recursive SMB share enumeration with smbclient and netexec, and offline hash cracking with John the Ripper.
- Exploitation and lateral movement. Authenticated SSH and RDP, UAC bypass on Windows, root-level access on the Finance server, and authenticated MySQL access to the internal database server.
- Persistence, data access, and reporting. Backdoor account creation on Windows and the Finance server, controlled extraction of a single proof-of-access record from the Finance database, and synthesis into this report.

3.2 Tools

Nmap, Hydra, Responder, John the Ripper, netexec, smbclient, xfreerdp, gobuster, the MySQL client, and standard Linux command-line utilities. The PwnKit binary (CVE-2021-4034) was transferred to the HRIS server as part of a privilege escalation attempt; root was not confirmed.

Severity matrix.

How impact and exploitability combine to produce the four severity ratings used throughout this report.

Each finding in this report is rated using the criteria below. Severity is determined by the combination of impact (what an attacker can do with the issue) and exploitability (how easily the issue can be exploited under the engagement’s conditions).

SEVERITY	IMPACT	EXPLOITABILITY
	Full system compromise, unauthorized administrative access, theft of regulated data (PII, PCI, PHI), or a vulnerability that directly enables widespread compromise of the environment.	Exploitable with public tooling and no special preconditions, or already exploited during the engagement to demonstrate impact.
	Significant exposure of sensitive information, persistent unauthorized access, or a control failure that materially weakens defense in depth without on its own granting full compromise.	Reliably exploitable with standard tooling under the conditions present in the environment, but requires existing foothold or specific configuration.
MEDIUM	Limited information disclosure, weak hardening that does not directly grant access, or a configuration that increases attacker effort but is not directly exploitable.	Requires chained conditions, additional access, or specific information not readily available to an external attacker.
	Best-practice deviation or informational finding with minimal direct security impact.	Not directly exploitable; relevant only as part of a defense-in-depth review.

This engagement produced fourteen findings: eight Critical and six High. No Medium or Low findings are reported because the engagement was scoped as an authorized adversarial assessment focused on impact and chainable exposure rather than a comprehensive configuration audit.

05 · WHAT WE FOUND

Findings.

Fourteen findings, presented as cards. Each one identifies the asset, describes the issue, shows the evidence captured during testing, and recommends a remediation. All sensitive material has been redacted; engagement notes retain the unredacted artifacts.

F - 01HIGH

Sensitive Path Disclosure via robots.txt

ASSETHRIS web portal (hris.cyberlou.xyz) and Finance server (192.168.3.8)

DESCRIPTION

Both the HRIS web portal and the Finance server publish robots.txt files that explicitly enumerate sensitive internal paths in their Disallow directives. On the HRIS portal these include a development directory and a hidden clue file; on the Finance server they include a database backup, a development financial model, an administrative endpoint, a backups directory, and a debug API path.

robots.txt is a public file. Any path listed there is, by design, advertised to anyone who reads it. Using it to hide content is a category error that converts a directory discovery problem into a one-line read.

EVIDENCE

Figure 1 — Nmap http-robots.txt output for finance.cyberlou.xyz — eight disallowed paths disclosed.

Figure 2 — HRIS portal robots.txt retrieved via curl — /dev/ path led to the F-03 disclosure.

IMPACT

An attacker enumerating the application discovers high-value paths in seconds. The HRIS Disallow list led directly to the credential disclosure described in F-03; the Finance Disallow list named a database backup, a financial model, and a debug API that materially shortened reconnaissance.

REMEDIATION

- Remove sensitive paths from robots.txt entirely. Do not use robots.txt as a security control.
- Place sensitive content behind authentication and authorization checks rather than relying on obscurity.
- Use a reverse proxy or web application firewall to block unauthenticated access to administrative and backup paths.

F - 02CRITICAL

Weak SSH Password Policy on HRIS Server

A S S E T HRIS server, SSH service on port 22

D E S C R I P T I O N

The HRIS server's hruser account was protected by a four-digit numeric password. Combined with the password policy disclosed in F-03, the keyspace was bounded at 9,998 candidates. A constrained Hydra wordlist exhausted the space inside two hours despite a deliberate three-second inter-attempt delay.

A four-digit numeric password offers no meaningful resistance to online brute force on any service, and none at all to offline cracking if a hash were ever exposed.

E V I D E N C E

Figure 3 — Hydra reporting valid SSH credential pair for hruser — password redacted.

Figure 4 — Interactive SSH session as hruser on hriss.cyberlou.xyz (192.168.0.172).

I M P A C T

The cracked credential provided the team's initial foothold and made every downstream finding in this report possible. From the hruser shell the team enumerated the second subnet, located the Windows endpoint, the Finance server, and the database server, and pivoted into the rest of the engagement.

R E M E D I A T I O N

- Enforce a minimum twelve-character passphrase policy with mixed case, numbers, and symbols on every account. Numeric-only PINs of any length are not acceptable for SSH.
- Disable SSH password authentication on internet-facing or production hosts and require SSH key authentication.
- Implement an account lockout policy of five failed attempts followed by an exponential backoff to defeat online brute force outright.
- Rotate the hruser credential immediately and audit auth.log for prior brute force attempts against the account.

F - 0 3 **C R I T I C A L**

Plaintext User Inventory in Open Directory

A S S E T HRIS web portal — /dev/ directory listing

D E S C R I P T I O N

The HRIS web server had directory listing enabled on the /dev/ path advertised by robots.txt. The directory contained a Word document that named three internal user accounts (hrtestuser, hrdevuser, hruser) and stated the password policy in plain language: four-digit numeric, with 0000 and 9999 excluded.

This single document was the precondition that turned F-02 from an open-ended brute force into a bounded search of fewer than ten thousand candidates.

E V I D E N C E

Figure 5 — /dev/users.doc retrieved — three usernames and four-digit PIN policy disclosed.

I M P A C T

An attacker with no prior knowledge of the environment learned the complete user inventory and the structure of the password used to protect those accounts. The combination is sufficient to fully automate the attack documented in F-02.

R E M E D I A T I O N

- Disable directory listing across all web servers in the environment. On Apache: Options -Indexes.
- Remove all credential, account, and policy documentation from web-accessible directories.
- Audit every web server in the environment for analogous disclosures, not only the one in scope.

F - 0 4 **H I G H**

Weak Webmin Administrator Password

A S S E T HRIS server, Webmin administrative interface on port 8200

DESCRIPTION

During post-exploitation of the HRIS server (F-02) the team recovered the Webmin administrator account password from cracking artifacts present on the host. The recovered credential authenticated to the Webmin web interface, granting full server administration including file management, terminal access, and service control.

The recovered password was a short common-word string trivially recoverable from any standard wordlist. Webmin specifically warrants higher protection because it is, by design, a tool for full system administration over the network.

EVIDENCE

Figure 6 — John the Ripper recovering the Webmin admin password — value redacted.

IMPACT

Webmin administrative access is functionally equivalent to root on the host. An attacker can browse and modify the filesystem, restart services, read every file owned by every user, and pivot from there to other systems via stored credentials and SSH key material.

REMEDIATION

- Rotate the Webmin administrator password to a strong unique value of at least sixteen characters.
- Restrict Webmin access to an administrative VLAN or jump host; do not expose it to general network segments.
- Enable Webmin's built-in two-factor authentication.
- Audit Webmin access logs since the last credential rotation to identify any unauthorized prior use.

F - 0 5 HIGH

SMB Signing Not Required on Windows Endpoint

ASSET DESKTOP-V4C365B (192.168.3.120), SMB service on port 445

DESCRIPTION

Nmap's smb2-security-mode script reported message_signing as "enabled but not required" on the Windows endpoint. SMB signing is the cryptographic integrity check that prevents an on-path attacker from tampering with SMB traffic and, more importantly, from relaying captured authentication material to other hosts. "Enabled but not required" means clients can choose to skip signing, which lets a relay attacker negotiate the unsigned variant and proceed exactly as if signing were disabled outright.

With signing not enforced, every NTLMv2 challenge-response captured on the network is a candidate for relay or offline cracking attacks.

EVIDENCE

Figure 7 — smb2-security-mode on 192.168.3.120 reports signing enabled but not required.

IMPACT

This finding was the precondition for the NTLMv2 capture and crack documented in F-06. With signing required, the captured authentication material would have been useless for relay; without enforcement, the entire Windows compromise chain became viable.

REMEDIATION

- Enable "Microsoft network server: Digitally sign communications (always)" via Group Policy across every Windows host in the environment, not only the one in scope.
- Disable the legacy SMBv1 protocol if still enabled.
- Audit all hosts using nmap --script smb2-security-mode after rollout to confirm coverage.

F - 0 6 CRITICAL

NTLMv2 Hash Capture and Offline Crack

ASSET DESKTOP-V4C365B (192.168.3.120)

DESCRIPTION

With SMB signing disabled (F-05) and LLMNR/NBT-NS broadcast resolution active on the local network, a Responder instance on the assessment workstation captured an NTLMv2 challenge-response for a standard domain user. The hash was passed to John the Ripper with a standard wordlist and recovered offline within minutes.

The recovered credential authenticated to both SMB and RDP on the endpoint and provided the team's initial Windows foothold.

EVIDENCE

Figure 8 — Responder captures NTLMv2 hash for pbest; John recovers password; netexec validates — values redacted.

IMPACT

Successful authentication to SMB and RDP enabled enumeration of the Operations share documented in F-07 and F-08, RDP access to the host, and ultimately the privilege escalation and persistence steps in F-09.

REMEDIATION

- Disable LLMNR via Group Policy: Computer Configuration → Administrative Templates → Network → DNS Client → Turn off Multicast Name Resolution → Enabled.
- Disable NetBIOS over TCP/IP on every adapter where it is not required.
- Enable SMB signing across the environment (see F-05) to neutralize relay attacks even if hashes are captured.
- Migrate user accounts to passphrase-based passwords of sufficient length to be resistant to offline cracking against common wordlists.
- Treat the affected account as compromised: rotate the password and review recent activity in the security logs.

F - 07 CRITICAL

Plaintext Credentials in Operations SMB Share

ASSET Windows endpoint — \\Operations\ResourceManagement\Staffing

DESCRIPTION

After authenticating with the credential captured in F-06, recursive enumeration of the Operations SMB share revealed a plaintext file named passwords.txt under ResourceManagement\Staffing. The file contained credentials for an Operations staff account, which authenticated successfully to RDP on the same workstation.

From that interactive session the team performed a UAC bypass leveraging a separate administrative account observed during user enumeration, escalating to an administrative PowerShell session.

EVIDENCE

Figure 9 — netexec lists Operations share as readable — password redacted.

Figure 10 — smbclient retrieves passwords.txt from Operations\\ResourceManagement\\Staffing — credential redacted.

IMPACT

A plaintext credential file inside a network share gave the team a second account on the Windows endpoint and a path to administrative privileges through the UAC bypass that followed.

REMEDIATION

- Remove passwords.txt from the SMB share immediately and rotate the affected account password.
- Audit every SMB share in the environment for plaintext credentials, configuration files containing secrets, and key material.
- Apply least-privilege ACLs to SMB shares. Operations staff should not have read access to credential storage or any folder outside their job function.
- Implement a managed secrets vault (HashiCorp Vault, Azure Key Vault, CyberArk) and prohibit storage of credentials in unprotected files by policy.

F - 08 CRITICAL

Database Administrator Credentials in SMB Share

ASSET Windows endpoint — \\Operations (training document)

DESCRIPTION

A separate file in the Operations SMB share, a Rich Text Format document titled as a database administration training reference, embedded a working set of MySQL credentials. These credentials authenticated to the print-server MySQL instance on the printer and, more critically, to the broader internal database server at 192.168.3.228 covered in F-13.

The document was readable by the same low-privilege user used to enter the share, which made the credential available to anyone with the foothold from F-06.

EVIDENCE

Figure 11 — training.rtf disclosed MySQL credentials for the print server and central DB — value redacted.

IMPACT

These credentials provided the pivot from the Windows endpoint into the internal database server and ultimately enabled the customer-data extraction documented in F-12.

REMEDIATION

- Remove the document from the share immediately and rotate the affected database credential.
- Review the database account's grants and apply least privilege; this account should not retain SELECT on the mysql.user table or any privilege beyond what its documented role requires.
- Train staff on the requirement that operational documentation and runbooks must never contain live credentials. Use templates with placeholder text and reference the secrets vault for live values.

F-09 HIGH

Persistent Backdoor Account Created on Windows Endpoint

ASSET DESKTOP-V4C365B (192.168.3.120)

DESCRIPTION

After obtaining administrative PowerShell on the Windows endpoint via the F-07 escalation chain, the team created a local administrative account named HackForceOne and added it to both the Administrators and Remote Desktop Users groups. The account was used to verify persistence and is documented here so it can be removed during remediation.

This is an engagement artifact. It is included in the report so the client can clean up after the assessment, not as a finding against the client's baseline configuration.

EVIDENCE

Figure 12 — Evil-WinRM session creates HackForceOne backdoor and adds it to Administrators — password redacted.

IMPACT

Until removed, the HackForceOne account provides persistent administrative access to the Windows endpoint that is independent of any compromise vector documented elsewhere in this report.

REMEDIATION

- Remove the HackForceOne account immediately: net user HackForceOne /delete on the Windows endpoint.
- After removal, audit the host for any other unexpected local accounts, scheduled tasks, services, or registry Run keys that might constitute persistence.
- Forward Windows Security event log entries 4720 (account creation), 4728/4732 (group membership change) to a SIEM and alert on creation of local administrative accounts.

F-10 CRITICAL

Finance Server Compromise via Webmin Backdoor (CVE-2019-15107)

ASSET Finance server (192.168.3.8 / finance.cyberlou.xyz), Webmin on port 28840

DESCRIPTION

Service-level scanning of the Finance server identified a Webmin instance on TCP port 28840. Webmin running on a non-standard port masked the service in casual scans but did not change the underlying version, which was vulnerable to CVE-2019-15107 — a remote command execution flaw introduced by a backdoor in the official Webmin distribution between 2018 and 2019. The Metasploit module exploit/linux/http/webmin_backdoor delivered a cmd/unix/reverse_python payload that returned a command shell as the Webmin process owner, which on this host was root.

As a non-destructive proof of access, the team recorded the timestamp on the /lost+found directory (March 21, 22:23) and committed it to the engagement notes. No production data was modified.

Full root access on a finance application server represents the highest-impact category of compromise: complete control of the host, the application, and any data the host can reach.

EVIDENCE

Figure 13 — Nmap identifies MiniServ 1.900 (Webmin) on TCP 28840 — the exploit entry point.

Figure 14 — Metasploit configures webmin_backdoor; target reported vulnerable.

Figure 15 — Reverse shell as root on 192.168.3.8; /lost+found timestamp Mar 21 22:23.

IMPACT

Root on the Finance server enables credential theft from the host and the application database, modification of application logic and audit logs, and pivoting into any other system the host can reach. The Webmin backdoor exploited here is documented and signature-detectable; the existence of a vulnerable version in production indicates a patch-management failure.

REMEDIATION

- Patch Webmin immediately to a version released after the backdoor was removed (1.930 or later); verify by checking the version banner returned on the management port.
- Treat the host as fully compromised. Rebuild from a known-good image rather than attempting in-place cleanup; an attacker with prior root could have planted persistence (cron, systemd units, modified sshd, web shells) that account-level audits will not catch.
- Rotate every credential that ever existed on or was reachable from the host, including database service accounts and any SSH keys.
- Place Webmin behind an administrative VLAN or jump host. Webmin should never be exposed on a network segment reachable from user or guest devices, regardless of the port number.
- Forward auth.log, syslog, and the application access logs to a SIEM going forward.

F-11 HIGH

Persistence Account Created on Finance Server

ASSET Finance server (192.168.3.8)

DESCRIPTION

Following root access on the Finance server (F-10), the team created a Linux user account named HackForceOne to verify persistence independent of the original compromise vector. The account was given a strong unique passphrase (held in the engagement notes), added to the sudo group, and verified through a second login. The account is documented here so it can be removed during remediation.

As with F-09, this is an engagement artifact rather than a finding against the client's baseline.

EVIDENCE

Figure 16 — HackForceOne created on Finance server with sudo — passphrase redacted.

Figure 17 — SSH login as HackForceOne on finance-470001; sudo -l confirms (ALL : ALL) ALL.

IMPACT

Until removed, the HackForceOne account on the Finance server provides persistent administrative access independent of the F-10 compromise vector. With sudo — ALL granted, the account can re-establish root at will.

REMEDIATION

- Remove the HackForceOne account from the Finance server: `userdel -r HackForceOne`.
- After removing the account, rebuild the host as recommended in F-10 — `userdel` does not detect or remove other persistence mechanisms a prior root could have planted.
- Forward auth.log to a SIEM and alert on `useradd`, `passwd`, and `sudoers` modifications.

F-12 CRITICAL

Customer Credit Card Data Exfiltration (Proof of Access)

ASSET Finance application database

DESCRIPTION

With root access to the Finance server (F-10), the team queried the customers table and retrieved one record's primary account number as proof of access. The retrieved value is held in the engagement notes and is not reproduced in this report. No additional records were extracted or retained.

Storing primary account numbers in cleartext (or in any reversibly recoverable form) inside an application database is a direct violation of PCI-DSS requirements 3.4 and 3.5 and represents a critical breach of customer trust independent of any external attacker.

EVIDENCE

IMPACT

Storage of primary account numbers in a recoverable form exposes Cyberlou Corporation to a confirmed cardholder-data incident under PCI-DSS, regardless of whether this engagement's extraction is treated as benign. Any attacker with database access can extract the entire customers table in seconds.

REMEDIATION

- Treat this as a confirmed cardholder-data incident under PCI-DSS. Engage your Qualified Security Assessor and follow your incident-response plan.
- Replace direct card storage with tokenization. Tokens cannot be reversed without access to the tokenization service, which lives in a separate hardened security zone.
- If card data must be retained at all, implement strong well-managed encryption at rest (PCI-DSS 3.5/3.6) with HSM-backed keys.
- Apply column-level access control so application accounts read only the fields they need.
- Notify any affected customers and the relevant card brands per regulatory requirements once incident scope is confirmed.

F-13 HIGH

Default Administrative Credentials and Cached Data Exposure on Network Printer

ASSET Konica Minolta C300i printer (192.168.3.116)

DESCRIPTION

The printer's web management interface on port 8200 accepted a default-style administrative credential. The configured password was a sixteen-character repeating numeric pattern that bypasses simplistic length-based password meters but is functionally a default credential.

A second issue compounds the first: the printer's /cache endpoint exposed previously printed jobs without authentication, providing a parallel disclosure path that bypasses the credential control entirely. A customer invoice with full billing details was retrievable from the endpoint.

Multifunction printers commonly cache email, scan-to-folder credentials, and print jobs, which makes a compromised printer a meaningful pivot, not a low-impact device.

EVIDENCE

Figure 19 — Printer port scan and 192.168.3.0/24 subnet sweep — eight live hosts identified.

Figure 20 — Invoice retrieved from /cache; admin login via default credential — password redacted.

IMPACT

An attacker with network access to the printer can read every cached print job (which often includes invoices, contracts, and HR documents), modify scan-to-folder configurations to redirect captured documents, and use the device as a foothold inside the network segment.

REMEDIATION

- Rotate the printer administrator password to a strong unique value.
- Disable cached job retention if the feature is not required. Where retention is required, restrict cache access to authenticated users only.
- Place network-attached printers on a management VLAN with restrictive ACLs so only authorized hosts reach the management port.
- Disable any unused services on the printer (FTP, telnet, SNMPv1/v2c) and standardize on SNMPv3 with authentication.
- Implement a job-clearing schedule so cached print data does not accumulate.

F-14 CRITICAL

Unauthorized Access to Internal Database Server

ASSET Internal database server (192.168.3.228), MySQL on port 3306

DESCRIPTION

Using the database credentials disclosed in F-08, the team authenticated to the internal MySQL instance on 192.168.3.228 from inside the network. The account had read access to the mysql.user table itself, which made every other account's password hash extractable.

A privileged account labeled in the database as a flag-acquiring account was identified during the same enumeration. Its hash was extracted to the engagement notes; cracking was not pursued during the engagement window.

EVIDENCE

IMPACT

Authenticated database access exposes every record in every accessible schema. The ability to read mysql.user multiplies the impact: every other database account becomes a candidate for offline cracking, including high-privilege ones.

REMEDIATION

- Rotate the affected low-privilege credential and audit its grants. The account should not have SELECT on mysql.user; that grant alone allows password-hash extraction for every account in the database.
- Restrict MySQL bind addresses and host filters so only authorized application hosts can connect.
- Migrate the privileged flag-acquiring account to a properly scoped role with only the privileges it needs and rotate its credential.
- Enable MySQL audit logging and forward to a SIEM.

06 · AT A GLANCE

Vulnerability summary.

Every finding consolidated into a single table by ID, severity, affected asset, and exploitation status.

ID	FINDING	SEVERITY	AFFECTED ASSET
F-01	Sensitive path disclosure via robots.txt		HRIS, Finance
F-02	Weak SSH password policy on HRIS server		HRIS server
F-03	Plaintext user inventory in open directory		HRIS web portal
F-04	Weak Webmin administrator password		HRIS server
F-05	SMB signing disabled on Windows endpoint		DESKTOP-V4C365B
F-06	NTLmv2 hash capture and offline crack		DESKTOP-V4C365B
F-07	Plaintext credentials in Operations SMB share		Operations share
F-08	Database admin credentials in SMB share		Operations share
F-09	Persistent backdoor account on Windows endpoint		DESKTOP-V4C365B
F-10	Finance server root access		Finance server
F-11	Persistence account on Finance server		Finance server
F-12	Customer credit card data exfiltration		Finance database
F-13	Default credentials and cached data on printer		Konica printer
F-14	Unauthorized access to internal database server		DB server (192.168.3.228)

07 · WHAT TO DO

Recommendations.

A prioritized rollup of remediation work. The first three items would have broken the entire compromise chain on their own.

Recommendations are grouped by remediation horizon. Items in 6.1 should be completed within seven days. Items in 6.2 within thirty days. Items in 6.3 are programmatic improvements that take longer to implement but materially harden the environment.

6.1 Immediate (within seven days)

- Remove the engagement persistence accounts (HackForceOne on the Windows endpoint per F-09, HackForceOne on the Finance server per F-11) and audit each host for additional unexpected accounts and persistence mechanisms.
- Rebuild the Finance server from a known-good image rather than cleaning in place. Root access during the engagement could have planted persistence not visible to account-level audits.
- Rotate every credential listed in Section 5 and any credential reachable from the compromised hosts. Treat all of them as known-bad.
- Remove plaintext credential files (passwords.txt, the database administration training document, the user inventory document) from every web and network share.

- Remove sensitive paths from robots.txt on HRIS and Finance servers, and disable directory listing on every web server.
- Enable SMB signing across the Windows estate via Group Policy.
- Engage a Qualified Security Assessor regarding the cardholder data incident documented in F-12 and follow the established incident-response plan.

6.2 Short term (within thirty days)

- Enforce a minimum twelve-character passphrase policy with mixed case, numbers, and symbols on every account on every system. Numeric-only PINs are not acceptable for any service.
- Implement an account lockout policy of five failed attempts followed by exponential backoff on every authentication surface (SSH, RDP, Webmin, web admin panels).
- Disable LLMNR and NetBIOS over TCP/IP via Group Policy across the Windows estate.
- Disable SSH password authentication on production hosts; require SSH key authentication.
- Patch CVE-2021-4034 (PwnKit) on the HRIS server and verify polkit version on every Linux host.
- Implement network segmentation between the 192.168.0.0/24 and 192.168.3.0/24 segments. The lateral movement that drove most of this report assumed unrestricted east-west traffic.
- Apply least-privilege ACLs on every SMB share. Reset share permissions to deny by default.
- Place network-attached printers on a management VLAN. Disable cached job retention or restrict /cache to authenticated users.

6.3 Programmatic (ninety days and beyond)

- Deploy a SIEM and forward authentication, system, and application logs from every system in scope. Alert on local admin account creation, useradd, and SMB authentication anomalies.
- Conduct annual third-party penetration tests and quarterly internal vulnerability scans.
- Deploy a managed secrets vault (HashiCorp Vault, Azure Key Vault, CyberArk). Prohibit credential storage in unprotected files by written policy.
- Implement multi-factor authentication on every administrative interface and remote access surface.
- Deploy LAPS for local administrator passwords on Windows endpoints.
- Replace direct card storage in the Finance application with a tokenization service. Card data, where retained at all, must be encrypted at rest with HSM-backed keys per PCI-DSS 3.5/3.6.
- Run regular awareness training focused on secure credential handling and avoidance of plaintext credential storage in operational documentation.

Conclusion.

A short statement of the engagement’s outcome, the highest-leverage remediation, and the path forward.

The Cyberlou environment failed to several categories of low-effort attack: weak password policy, plaintext credential storage on network shares, insecure SMB configuration, sensitive path disclosure via robots.txt, and unauthenticated cached data on a network printer. Individually each issue is recoverable. Together they composed an attack chain that took the team from outside the network to root on a finance application server with extracted customer payment data, in a single engagement window.

The finance server compromise is the headline outcome and warrants a treated-as-incident response under the cardholder-data framework. The other findings collectively describe a baseline that needs hardening rather than triage: every recommendation in Section 7 corresponds to a control that should already exist and does not.

The single highest-leverage remediation is the password policy in F-02 and F-03. Hardening that one control would have broken the chain at its first link. Every recommendation in Section 7.1 should land first; the rest of the program follows from there.

Screenshot capture index.

Per-figure source: which finding it supports, which system to capture from, and the exact command or browser action that produces the screen.

#	FINDING	CAPTURE TARGET	SOURCE COMMAND / ACTION
1	F-01	HRIS robots.txt in browser	GET https://hris.cyberlou.xyz/robots.txt

2	F-01	Finance robots.txt in browser	GET http://192.168.3.8/robots.txt
3	F-03	Open /dev/ directory listing	GET https://hris.cyberlou.xyz/dev/
4	F-03	User inventory document content	Open users.doc, screenshot the policy text
5	F-02	Hydra success line	hydra -l hruser -P pins.txt -t 4 -W 3 ssh://hris.cyberlou.xyz
6	F-02	SSH session post-login	ssh hruser@hris... ; whoami; id; ls -la
7	F-04	Authenticated Webmin dashboard	Browser at https://hris.cyberlou.xyz:8200
8	F-05	Nmap SMB security mode output	nmap --script smb2-security-mode 192.168.3.120
9	F-06	Responder NTLMv2 capture moment	sudo responder -I eth0 -vv
10	F-06	John the Ripper completing the crack	john pbest.hash --wordlist=/usr/share/wordlists/rockyou.txt
11	F-06	netexec authentication success	netexec smb 192.168.3.120 -u <user> -p <pass>
12	F-07	smbclient recursive listing of Operations share	smbclient //192.168.3.120/Operations -U <user>
13	F-07	xfreerdp interactive desktop	xfreerdp /u:<user> /p:<pass> /v:192.168.3.120
14	F-08	Training document with embedded credentials	Open the document in a viewer
15	F-09	Backdoor account verification	net user / net localgroup; subsequent RDP login
16	F-10	Finance root shell	whoami; id; ls -la /lost+found
17	F-11	HackForceOne (Finance) verification	getent passwd HackForceOne; sudo -l
18	F-12	Finance database SELECT (PAN redacted)	mysql -h 192.168.3.8 -u <user> -p
19	F-13	Authenticated printer admin dashboard	Browser at http://192.168.3.116:8200
20	F-13	Unauthenticated /cache invoice	GET http://192.168.3.116:8200/cache
21	F-14	mysql session on internal DB	mysql -h 192.168.3.228 -u <user> -p